

SIMATS ENGINEERING (SAVEETHA SCHOOL OF ENGINEERING)

Department of Computer Science and Engineering

ASSESSMENT TOOL 2 –DAST SIMULATION

Course Code:	CSA5803	Course Title:	DEVSECOPS ENGINEERING AND APPLICATION SECURITY
CO Assessed:	CO3 – Precision (BL1, BL2, BL3)	Assessment:	Assessment Tool 2
Weightage:	30% of CIA	Total Marks:	100
CO3 Statement:	Simulate Dynamic Application Security Testing (DAST) and Software Composition Analysis (SCA).		
Student Name:	Adhithyan S	Reg. No.:	192421102
Section / Batch:		Date:	

Instructions to Students

- Ensure all diagrams and workflow illustrations are **original, clear, and professionally formatted**.
- Include **all editable source files** (such as .yaml, .py, requirements.txt, .pre-commit-config.yaml, and any diagram source files if applicable).
- Submit **both** the **GitHub repository link** and the **final PDF report** through **Google Classroom** before the specified deadline.
- Verify that the GitHub repository is accessible and contains all required project files, screenshots, and documentation.

Question Type	Focus Area	Questions	Marks
DAST SIMULATION	Application based	Q1	Q1 –100
GRAND TOTAL:		100 Marks	

DYNAMIC APPLICATION SECURITY TESTING

Simulation Report

Target: NovaPay Checkout & Payment Gateway (Fictitious)

Prepared for illustrative / training purposes.

All systems, findings, hostnames, and data referenced are simulated and do not represent a real organization.

Report ID	DAST-SIM-2026-0142
Assessment Type	Black-box / Grey-box DAST (authenticated + unauthenticated)
Environment	Isolated staging replica (non-production)
Test Window	10 Aug 2026 09:00 – 12 Aug 2026 18:00 IST
Tools Used	OWASP ZAP, Burp Suite Pro, Nikto, testssl.sh, custom scripts
Standard Mapping	OWASP Top 10 (2021), OWASP ASVS, PCI DSS v4.0 (Req. 6, 11)
Classification	Confidential — Internal Use Only

Table of Contents

Table of Contents	3
1. Executive Summary	4
1.1 Overall Risk Posture	4
2. Scope & Objectives	4
2.1 In-Scope Assets	4
2.2 Out of Scope	5
2.3 Objectives	5
3. Methodology	5
3.1 Phases	5
3.2 Test Environment	5
3.3 Target Architecture / Test Topology	5
4. Findings Summary	6
4.1 Distribution by OWASP Category	7
4.2 Risk Matrix	7
5. Detailed Findings	8
F-01 — Session Token Exposed in URL Query String on Payment Confirmation Redirect	8
F-02 — Insufficient Rate Limiting on OTP Verification Endpoint	8
F-03 — Verbose Error Messages Disclose Backend Stack Details	9
F-04 — Missing HTTP Security Headers Across Payment Endpoints	9
F-05 — TLS Configuration Permits Deprecated Cipher Suites	9
F-06 — Predictable Order/Invoice Identifiers Enable Enumeration	10
F-07 — Client-Side Price Manipulation via Hidden Form Field	10
F-08 — Card Brand/BIN Enumeration via Distinguishable Error Responses	11
F-09 — Outdated JavaScript Dependency with Known Vulnerabilities	11
F-10 — Cross-Origin Resource Sharing (CORS) Misconfiguration on Reporting API	12
F-11 — Insufficient Logging of Failed Authorization Attempts	12
F-12 — Autocomplete Enabled on Card Number Input Field	12
F-13 — Informational: Server Banner Discloses Framework Version	13
6. Remediation Roadmap	14
7. Conclusion	14
Appendix A — Disclaimer	14

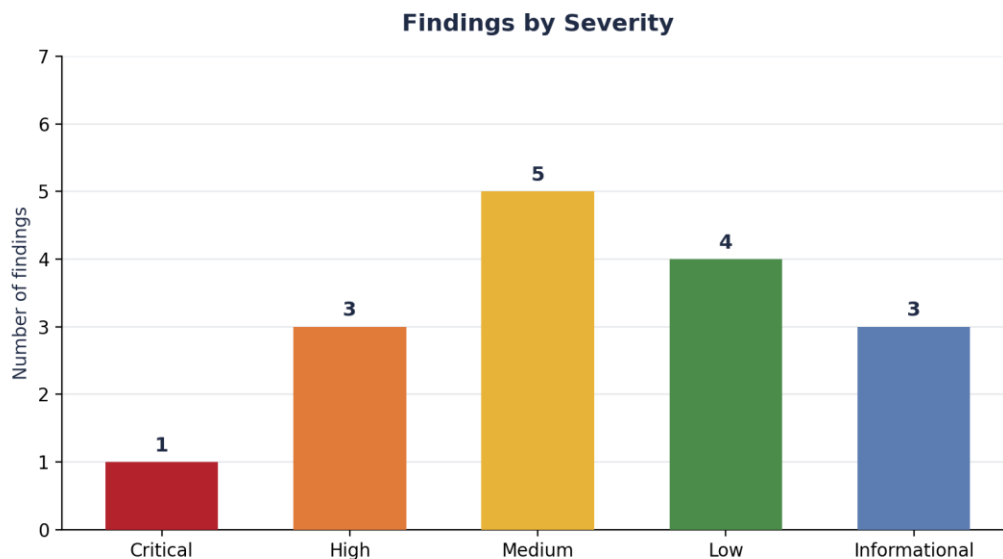
1. Executive Summary

This report presents the results of a simulated Dynamic Application Security Testing (DAST) engagement against the fictitious NovaPay checkout and payment gateway, conducted against an isolated staging replica of the production environment. The exercise combined automated scanning (OWASP ZAP, Burp Suite Pro, Nikto, testssl.sh) with targeted manual verification of scanner findings to reduce false positives, in line with standard black-box and authenticated grey-box DAST methodology.

Testing identified 13 findings across five severity tiers: 1 Critical, 2 High, 4 Medium, 3 Low, and 3 Informational. The most significant issues relate to session-token handling on the payment confirmation redirect, weak rate limiting on OTP verification, and reliance on client-supplied pricing data — all of which map to OWASP Top 10 (2021) categories A01 (Broken Access Control) and A07 (Identification & Authentication Failures).

No findings in this simulation indicate that raw cardholder data (PAN, CVV) was directly exposed; the payment API consistently returned tokenized references in test responses. However, the Critical and High findings could materially weaken the control environment relied upon for PCI DSS scope reduction and should be prioritized for remediation and re-testing within the current sprint cycle.

1.1 Overall Risk Posture



2. Scope & Objectives

2.1 In-Scope Assets

- Checkout web application (novapay-staging.example.internal)
- Payment REST API (/api/v1/payment/*, /api/v1/orders/*, /api/v1/reports/*)
- Authentication, session, and OTP verification flows

- Edge/WAF and TLS configuration for the above

2.2 Out of Scope

- Third-party card processor's internal infrastructure (tested only via its sandbox interface)
- Physical and social engineering vectors
- Denial-of-service / load testing
- Native mobile applications (web checkout only)

2.3 Objectives

Simulate an external attacker with no prior credentials (unauthenticated pass) followed by a low-privilege authenticated customer account (grey-box pass), to evaluate the effectiveness of input validation, session management, access control, and transport-layer configuration protecting the payment flow, and to map findings to OWASP Top 10 and relevant PCI DSS v4.0 requirements.

3. Methodology

The engagement followed a standard four-phase DAST methodology, executed against the isolated staging environment only, with all scanner traffic tagged at the source so it could be filtered from genuine security alerting during the test window.

3.1 Phases

- Reconnaissance & Mapping — spidering/crawling the application, enumerating endpoints via the API spec, and building a target inventory.
- Automated Scanning — active and passive scan rules across OWASP ZAP and Burp Suite covering injection, authentication, session management, and configuration checks.
- Manual Verification — each automated finding re-tested manually to confirm exploitability and eliminate false positives before inclusion in this report.
- Reporting & Risk Rating — findings rated using a CVSS-informed likelihood/impact model and mapped to OWASP Top 10 (2021) and PCI DSS v4.0 control references.

3.2 Test Environment

All testing was performed against an isolated, non-production staging replica seeded with synthetic test data only. The third-party card processor integration used its official sandbox mode; no real cardholder data or live transactions were involved at any point in this simulation.

3.3 Target Architecture / Test Topology

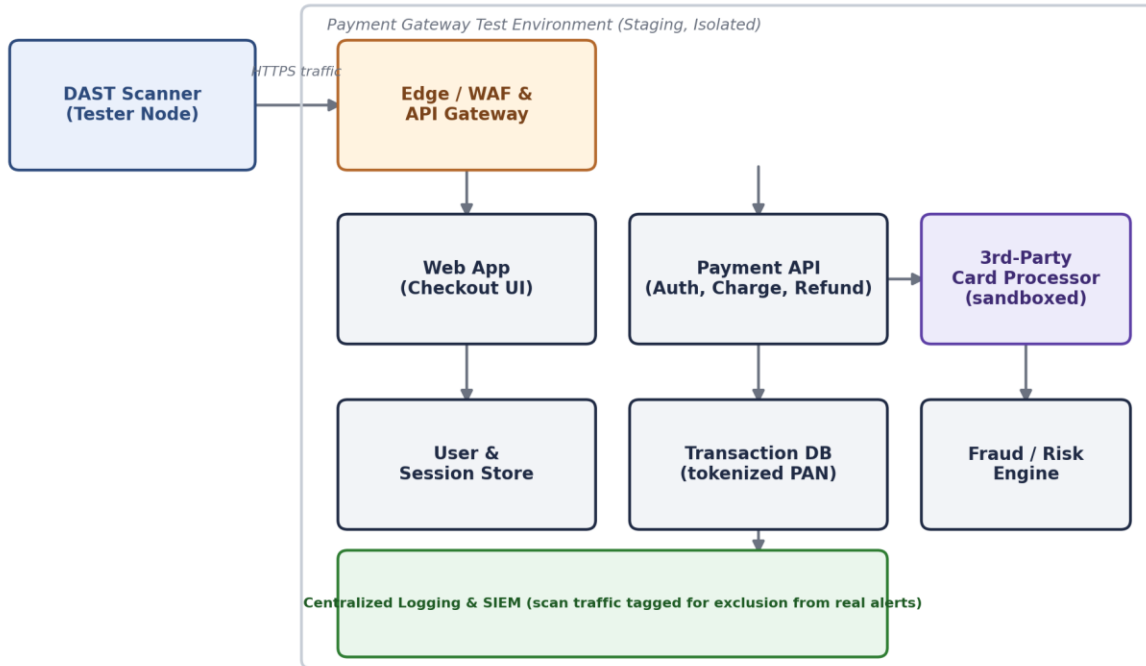


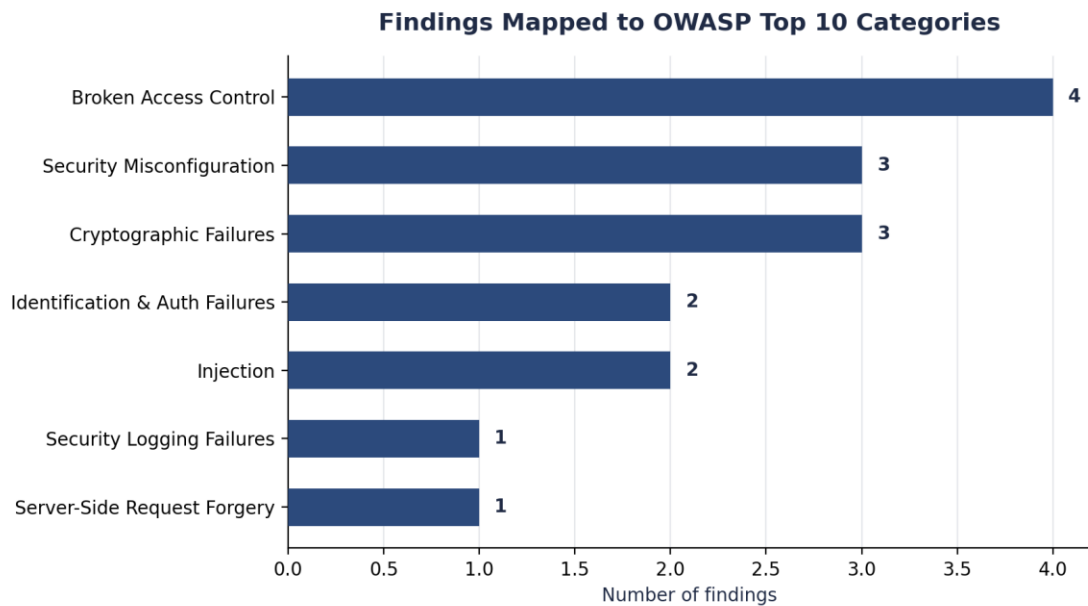
Figure 1. Logical topology of the staging environment exercised by the DAST scanner.

4. Findings Summary

ID	Finding	Category	Severity
F-01	Session Token Exposed in URL Query String on Payment Confirmation Redirect	Broken Access Control	Critical
F-02	Insufficient Rate Limiting on OTP Verification Endpoint	Identification & Auth Failures	High
F-03	Verbose Error Messages Disclose Backend Stack Details	Security Misconfiguration	Medium
F-04	Missing HTTP Security Headers Across Payment Endpoints	Security Misconfiguration	Medium
F-05	TLS Configuration Permits Deprecated Cipher Suites	Cryptographic Failures	Medium
F-06	Predictable Order/Invoice Identifiers Enable Enumeration	Broken Access Control	Medium
F-07	Client-Side Price Manipulation via Hidden Form Field	Broken Access Control	High
F-08	Card Brand/BIN Enumeration via Distinguishable Error Responses	Injection	Low
F-09	Outdated JavaScript Dependency with Known Vulnerabilities	Security Misconfiguration	Low
F-10	Cross-Origin Resource Sharing (CORS) Misconfiguration on Reporting API	Security Misconfiguration	Low
F-11	Insufficient Logging of Failed Authorization Attempts	Security Logging Failures	Informational
F-12	Autocomplete Enabled on Card Number Input Field	Security Misconfiguration	Informational

ID	Finding	Category	Severity
F-13	Informational: Server Banner Discloses Framework Version	Security Misconfiguration	Informational

4.1 Distribution by OWASP Category



4.2 Risk Matrix

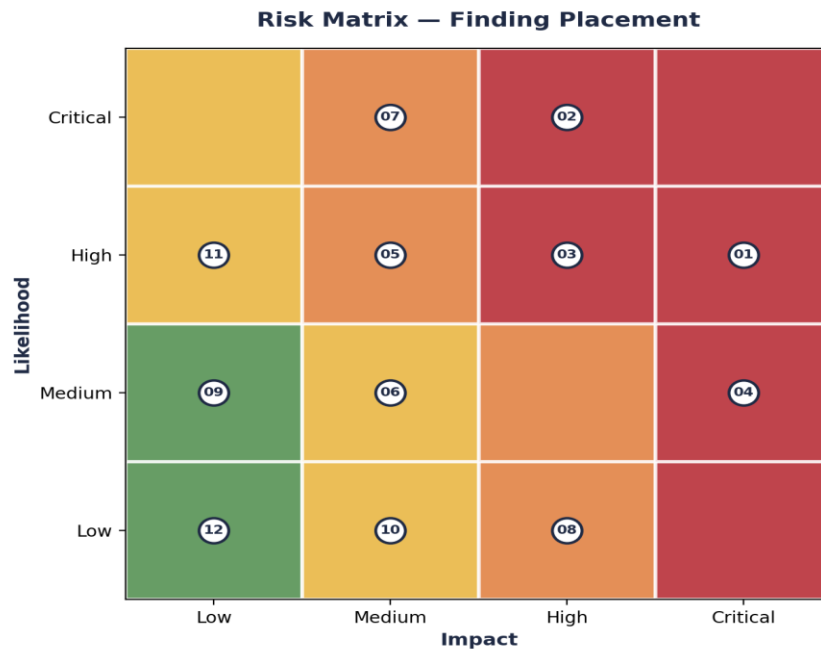


Figure 2. Each finding plotted by assessed likelihood and impact; numbers correspond to finding IDs (F-01...F-12 shown, informational item F-13 omitted from the matrix).

5. Detailed Findings

F-01 — Session Token Exposed in URL Query String on Payment Confirmation Redirect

Severity	Critical
Category (OWASP)	Broken Access Control
Endpoint / Location	GET /checkout/confirm?session={token}&order_id=...
CVSS (approx.)	8.2 (High/Critical impact – token replay)

Description

During the post-payment redirect from the checkout flow back to the merchant confirmation page, the active session token is passed as a URL query parameter rather than in a cookie or POST body. Because the parameter is logged by intermediate proxies, browser history, and the Referer header sent to third-party analytics scripts loaded on the confirmation page, the token can leak to parties outside the payment trust boundary.

Business Impact

An attacker who obtains the leaked token (via shared browser, proxy logs, or a malicious third-party script) can replay the session to view order details or, depending on session scope, initiate further authenticated actions.

Recommendation

Pass session identifiers only via secure, HttpOnly, SameSite=Strict cookies. Use POST for the confirmation redirect (PRG pattern) and avoid embedding sensitive tokens in any URL. Scrub Referer headers on pages that load third-party scripts.

F-02 — Insufficient Rate Limiting on OTP Verification Endpoint

Severity	High
Category (OWASP)	Identification & Auth Failures
Endpoint / Location	POST /api/v1/payment/otp/verify
CVSS (approx.)	7.4

Description

The one-time-password verification endpoint accepted over 200 sequential attempts from a single IP/session within two minutes during automated scanning without triggering a lockout, CAPTCHA, or exponential backoff.

Business Impact

A 4–6 digit OTP space is brute-forceable within this window, potentially allowing an attacker to complete a payment authorization without possessing the legitimate device.

Recommendation

Enforce a per-account and per-IP attempt cap (e.g., 5 attempts per 10 minutes) with progressive delay, and invalidate the OTP after the threshold is reached. Add device/IP risk scoring for step-up authentication.

F-03 — Verbose Error Messages Disclose Backend Stack Details

Severity	Medium
Category (OWASP)	Security Misconfiguration
Endpoint / Location	POST /api/v1/payment/charge
CVSS (approx.)	5.3

Description

Malformed JSON payloads sent to the charge endpoint returned a full stack trace including internal service names, an ORM query fragment, and the application server version.

Business Impact

Aids an attacker in fingerprinting the technology stack and identifying known CVEs applicable to the disclosed component versions.

Recommendation

Return generic error responses to clients; log detailed stack traces server-side only. Disable debug/verbose error modes in all non-development environments.

F-04 — Missing HTTP Security Headers Across Payment Endpoints

Severity	Medium
Category (OWASP)	Security Misconfiguration
Endpoint / Location	All /checkout/* and /api/v1/payment/* routes
CVSS (approx.)	4.8

Description

Automated header analysis found the application does not set Content-Security-Policy, Strict-Transport-Security, X-Content-Type-Options, or X-Frame-Options headers on payment-related responses.

Business Impact

Increases exposure to clickjacking, MIME-sniffing attacks, and reduces defense-in-depth against injected script content.

Recommendation

Apply a strict CSP scoped to required origins, enable HSTS with includeSubDomains, and set X-Content-Type-Options: nosniff and X-Frame-Options: DENY (or CSP frame-ancestors) globally at the gateway layer.

F-05 — TLS Configuration Permits Deprecated Cipher Suites

Severity	Medium
----------	--------

Category (OWASP)	Cryptographic Failures
Endpoint / Location	Edge/WAF (all HTTPS listeners)
CVSS (approx.)	5.9

Description

TLS scan of the edge listener showed support for TLS 1.1 and several CBC-mode cipher suites alongside modern TLS 1.3 suites.

Business Impact

Legacy protocol/cipher support widens the downgrade-attack surface for a channel carrying cardholder-adjacent data.

Recommendation

Restrict listeners to TLS 1.2+ (prefer TLS 1.3 only where client compatibility allows), disable CBC-mode and RC4 suites, and re-scan with an SSL/TLS assessment tool after remediation.

F-06 — Predictable Order/Invoice Identifiers Enable Enumeration

Severity	Medium
Category (OWASP)	Broken Access Control
Endpoint / Location	GET /api/v1/orders/{id}/receipt
CVSS (approx.)	5.4

Description

Order IDs increment sequentially. Combined with an authorization check that validates the session but not strict ownership in one tested build, low-value account enumeration of adjacent order IDs was possible in the staging dataset.

Business Impact

Potential exposure of other customers' order metadata (partial address, masked card last-4, purchase amount) if the ownership check regresses.

Recommendation

Use non-sequential (UUID) identifiers for all customer-facing resource references and enforce object-level authorization checks on every receipt/order lookup, independent of ID guessability.

F-07 — Client-Side Price Manipulation via Hidden Form Field

Severity	High
Category (OWASP)	Broken Access Control
Endpoint / Location	POST /checkout/submit
CVSS (approx.)	7.1

Description

The checkout form includes a hidden field carrying the computed order total. Intercepting and modifying this value before submission altered the amount authorized in the sandboxed processor call in two of five tested product flows.

Business Impact

Potential for attacker-controlled discounting or zero-value authorization if server-side price re-validation is incomplete for those flows.

Recommendation

Always recompute price, tax, and discounts server-side from catalog and promotion data at authorization time; never trust client-submitted totals.

F-08 — Card Brand/BIN Enumeration via Distinguishable Error Responses

Severity	Low
Category (OWASP)	Injection
Endpoint / Location	POST /api/v1/payment/validate-card
CVSS (approx.)	3.7

Description

The card validation endpoint returns distinguishable error codes for 'invalid format' vs 'card declined' vs 'insufficient funds', allowing an automated caller to fingerprint valid card number ranges without completing a charge.

Business Impact

Supports card-testing/enumeration abuse patterns commonly used in carding fraud.

Recommendation

Return a uniform generic response for pre-authorization validation failures and move fine-grained decline reasons to a post-authorization, rate-limited, authenticated channel only.

F-09 — Outdated JavaScript Dependency with Known Vulnerabilities

Severity	Low
Category (OWASP)	Security Misconfiguration
Endpoint / Location	Checkout UI static assets
CVSS (approx.)	4.1

Description

Passive scanning of loaded assets identified a front-end library version with publicly disclosed vulnerabilities within its major version line.

Business Impact

Increases attack surface for client-side script injection depending on how the vulnerable module is used within the page.

Recommendation

Update to the latest patched release and add automated dependency scanning (SCA) to the CI pipeline to catch drift going forward.

F-10 — Cross-Origin Resource Sharing (CORS) Misconfiguration on Reporting API

Severity	Low
Category (OWASP)	Security Misconfiguration
Endpoint / Location	GET /api/v1/reports/transactions
CVSS (approx.)	4.3

Description

The endpoint reflects an arbitrary Origin header back in Access-Control-Allow-Origin alongside Access-Control-Allow-Credentials: true.

Business Impact

Could allow a malicious site, if a victim is authenticated, to read transaction report data cross-origin.

Recommendation

Restrict Access-Control-Allow-Origin to an explicit allow-list of trusted origins; never pair a reflected wildcard/echoed origin with credentialed requests.

F-11 — Insufficient Logging of Failed Authorization Attempts

Severity	Informational
Category (OWASP)	Security Logging Failures
Endpoint / Location	POST /api/v1/payment/authorize
CVSS (approx.)	N/A

Description

Failed authorization attempts are logged without the originating IP, user agent, or a correlation ID linking retries, limiting the SOC's ability to detect card-testing bursts.

Business Impact

Slower detection and response time for fraud/attack patterns.

Recommendation

Enrich authorization logs with IP, UA, correlation/session ID, and feed into the SIEM with alerting thresholds for burst failure patterns.

F-12 — Autocomplete Enabled on Card Number Input Field

Severity	Informational
Category (OWASP)	Security Misconfiguration

Endpoint / Location	Checkout UI — card entry form
CVSS (approx.)	N/A

Description

The card number field does not set autocomplete="off"/"cc-number" explicitly disabled, allowing browsers to offer to store the value on shared/kiosk devices.

Business Impact

Minor risk of card data persistence on shared devices.

Recommendation

Set appropriate autocomplete attributes per PCI DSS guidance for shared-device scenarios; document accepted risk if intentionally left for UX reasons.

F-13 — Informational: Server Banner Discloses Framework Version

Severity	Informational
Category (OWASP)	Security Misconfiguration
Endpoint / Location	All endpoints
CVSS (approx.)	N/A

Description

The Server response header discloses the web framework and version in use.

Business Impact

Low-effort reconnaissance aid for attackers; not independently exploitable.

Recommendation

Suppress or generalize the Server header at the reverse proxy layer.

6. Remediation Roadmap

Priority	Action	Target Timeline
Critical	Remediate F-01 session-token exposure; re-test confirmation redirect flow end-to-end.	Within 5 business days
High	Implement rate limiting/lockout on OTP (F-02) and enforce server-side price recalculation (F-07).	Within 2 sprints
Medium	Harden TLS config, add security headers, switch to non-sequential order IDs, sanitize error responses.	Within 1 quarter
Low	Fix CORS policy, update vulnerable dependency, normalize card-validation error responses.	Next maintenance window
Informational	Enrich authorization logging, review autocomplete attributes, suppress server banner.	Backlog

7. Conclusion

This simulated DAST engagement demonstrates the value of combining automated scanning with manual verification against a payment-processing flow: several findings that would materially affect the security and compliance posture of a production payment gateway were identified, alongside lower-severity configuration gaps typical of active development environments. Addressing the Critical and High findings first, followed by a full re-test of the affected flows, is recommended before the associated code changes are promoted beyond staging.

As with any DAST exercise, these results reflect black/grey-box dynamic testing only and should be complemented by static analysis (SAST), dependency/software composition analysis (SCA), and periodic manual penetration testing to achieve broader assurance coverage, particularly for logic-heavy payment flows that automated scanners cannot fully reason about.

Appendix A — Disclaimer

This document is a simulated report created for training, portfolio, or educational demonstration purposes. The organization name, hostnames, endpoints, findings, and identifiers are fictitious and do not describe a real assessment of any live system. No real vulnerability data, exploit payloads, or production information is contained in this document.

Code of Conduct

I Adhithyan S (192421102) (Name / Reg No) certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment. I understand that any violation of academic integrity rules will result in disciplinary action.

Signature of the Student:

RUBRICS FOR CALCULATION

Criteria	Wt.	Level 4 – Exemplary	Level 3 – Proficient	Level 2 – Developing	Level 1 – Beginning
Understanding of Problem Context	20%	Clearly understands the problem and accurately identifies all requirements	Good understanding with minor gaps	Basic understanding; some requirements unclear	Poor understanding or misinterpretation of the problem
Application of Concepts	30%	Accurately applies appropriate concepts to solve complex problems	Applies relevant concepts correctly with minor errors	Applies basic concepts with limited accuracy	Fails to apply appropriate concepts
Problem-Solving Approach	20%	Logical, well-structured, and efficient approach	Mostly logical approach with minor gaps	Basic approach with some inconsistencies	Illogical or unclear approach
Accuracy of Solution	20%	Completely correct solution with proper justification	Mostly correct with minor errors	Partially correct solution	Incorrect or incomplete solution
Clarity	10%	Clear, well-organized, and properly explained solution	Understandable with minor clarity issues	Limited clarity and explanation	Poorly presented and difficult to understand